



Escuela Colombiana de Ingeniería Julio Garavito

Exfiltracion de informacion mediante RAG

Equipo de Ciberseguridad y desarrollo

Juan Pablo Caballero Castellanos

Robinson Steven Nuñez Portela

Oscar Andres Sanchez Porras

Declaramos bajo nuestro compromiso etico que las evidencias presentadas en este proyecto de ciberseguridad corresponden al trabajo realizado por los integrantes del grupo. Asimismo, certificamos que las herramientas de inteligencia artificial fueron utilizadas unicamente con fines academicos y de analisis, y que las practicas se desarrollaron en entornos controlados y autorizados.

Juan Pablo Caballero Castellanos

Robinson Steven Nuñez Portela

Oscar Andres Sanchez Porras

Fundamentos de Seguridad de la Información

Profesora: Tatiana Marcela Gomez Sarmiento

Septiembre de 2026

ABSTRACT

“This paper studies the exfiltration of information through Retrieval Augmented Generation systems. We describe the architecture of a RAG pipeline, the vectors that allow an attacker to retrieve restricted documents, and the mechanisms that enforce access filtering by user, role, and classification level. We also design a methodology for testing document level authorization and discuss the residual risks that remain even when filtering is enforced, so that a virtual assistant does not disclose confidential information to unauthorized users.”

Index Terms: RAG, large language models, access control, information classification, data exfiltration, confidentiality, OWASP.

Contenido

1	Introducción	1
2	Objetivo	1
2.1	Objetivo general	1
2.2	Objetivos específicos	1
3	Marco Teórico	2
3.1	Arquitectura de un sistema RAG	2
3.2	Vectores de exfiltración de información	2
3.3	Control de acceso por usuario, rol y clasificación	2
4	Metodología	2
4.1	Diseño del entorno de prueba	2
4.2	Ataques diseñados	3
4.3	Mecanismos de filtrado evaluados	3
5	Resultados y Análisis	3
5.1	Sistema sin filtrado	3
5.2	Sistema con filtrado por rol y clasificación	3
5.3	Riesgo residual	3
6	Discusión	3
6.1	Efectividad frente a las limitaciones conocidas	3
6.2	Balance entre seguridad y usabilidad	4
6.3	Protección del almacén vectorial	4
7	Conclusiones	4

1. INTRODUCCION

Los asistentes conversacionales corporativos utilizan cada vez con mayor frecuencia la generación aumentada por recuperación, técnica conocida en la literatura por sus siglas en inglés como RAG, para responder consultas apoyándose en documentos internos de una organización en lugar de depender únicamente del conocimiento aprendido durante el entrenamiento del modelo. Lewis et al. describieron este enfoque como una forma de combinar un modelo generativo con un componente de recuperación que consulta

una base de conocimiento externa antes de producir una respuesta [1].

Esta arquitectura resuelve problemas de actualidad y precisión de la información, pero introduce una superficie de ataque nueva. Cuando el contenido recuperado no respeta los permisos que la organización asigna a cada usuario, el asistente puede terminar exponiendo fragmentos de documentos restringidos a personas que jamás deberían haber tenido acceso a ellos. La fundación OWASP incorporó este riesgo en la categoría de debilidades de vectores e incrustaciones dentro de su listado de riesgos críticos para aplicaciones basadas en modelos de lenguaje, y advierte que un control de acceso insuficiente sobre el almacén vectorial puede filtrar información sensible entre distintos usuarios o inquilinos de un mismo sistema [2].

El presente trabajo aborda el escenario asignado al Grupo de Ciberseguridad y desarrollo dentro del curso Fundamentos de Seguridad de la Información: intentar recuperar documentos restringidos desde un sistema RAG y aplicar filtros de acceso según el usuario, el rol y el nivel de clasificación de la información, con el propósito de evitar que la inteligencia artificial revele información confidencial a usuarios no autorizados.

2. OBJETIVO

2.1 Objetivo general

Diseñar y evaluar mecanismos de control de acceso para un sistema RAG que impidan la exfiltración de documentos restringidos hacia usuarios sin los permisos correspondientes.

2.2 Objetivos específicos

- Caracterizar la arquitectura de un sistema RAG y los puntos donde puede producirse una fuga de información.
- Diseñar escenarios de prueba que intenten recuperar documentos restringidos mediante consultas directas e indirectas.
- Proponer y evaluar filtros de acceso aplicados por usuario, por rol y por nivel de clasificación de la información.
- Analizar la efectividad y las limitaciones de dichos filtros frente a técnicas de evasión conocidas.

3. MARCO TEORICO

3.1 Arquitectura de un sistema RAG

Un sistema RAG combina tres componentes principales: un corpus de documentos convertido en representaciones vectoriales llamadas incrustaciones, un motor de búsqueda por similitud que recupera los fragmentos más relevantes para una consulta, y un modelo de lenguaje que redacta la respuesta final apoyándose en dichos fragmentos. Esta separación entre memoria paramétrica y memoria no paramétrica mejora la precisión factual de las respuestas frente a un modelo que solo depende de lo aprendido durante el entrenamiento [1].

El problema de seguridad aparece porque, en la mayoría de implementaciones, el motor de búsqueda selecciona los fragmentos únicamente por similitud semántica, sin verificar si el usuario que hizo la pregunta tiene autorización para ver esos fragmentos. Un modelo entrenado o conectado a datos organizacionales segregados puede filtrar información privilegiada a usuarios sin permisos si no existe un mecanismo que reproduzca, dentro del propio sistema, la estructura de control de acceso que ya protege esos datos en su repositorio original [3].

3.2 Vectores de exfiltración de información

La literatura reciente identifica tres rutas principales por las que un sistema RAG puede exponer información que debería permanecer restringida.

Inyección de instrucciones. Un atacante puede ocultar órdenes dentro de un documento que será recuperado por el sistema, de modo que el modelo termine ejecutando esas órdenes en lugar de responder la consulta original. En un contexto RAG esta técnica se conoce como inyección indirecta y puede utilizarse para pedirle al modelo que ignore los filtros configurados y revele el contenido completo de un documento [4].

Envenenamiento del almacén vectorial. El ataque conocido como PoisonedRAG inserta deliberadamente documentos maliciosos en la base de conocimiento para que sean recuperados frente a consultas específicas y alteren la respuesta del modelo, lo que también puede aprovecharse para extraer información sensible almacenada junto a esos documentos [5].

Ausencia de autorización a nivel de documento. Buena parte de los sistemas desplegados no aplican controles en la etapa de recuperación, de modo que cualquier usuario autenticado en el chatbot puede acceder, mediante consultas ingeniosas, a fragmentos de documentos que pertenecen a otro departamento, a otro cliente o a un nivel de clasificación superior al que le corresponde [6].

3.3 Control de acceso por usuario, rol y clasificación

Para mitigar estos riesgos, la literatura propone trasladar al pipeline de recuperación los mismos modelos de control de acceso ya usados en sistemas de información tradicionales.

El control de acceso basado en roles agrupa a los usuarios según la función que desempeñan dentro de la organización y asigna permisos a esos roles en lugar de asignarlos a cada persona individualmente [7]. Aplicado a un sistema RAG, esto permite que un fragmento de documento solo sea recuperado cuando el rol de quien pregunta coincide con los roles autorizados a leer ese fragmento.

De manera complementaria, la norma ISO IEC 27001 en su versión 2022 exige, dentro del control A.5.12, que la información se clasifique según su confidencialidad, integridad y disponibilidad, definiendo niveles típicos como público, interno, confidencial y secreto [8]. Trasladar esta etiqueta de clasificación a los metadatos de cada fragmento indexado permite filtrar la búsqueda vectorial de modo que un usuario nunca reciba contenido con un nivel de clasificación superior al que su perfil autoriza.

Una prueba de concepto construida en el dominio de la salud integra reglas de acceso con la recuperación vectorial, de forma que un sistema RAG entrenado con perfiles de pacientes solo entrega a cada usuario la información que su rol clínico le permite consultar. Sus autores concluyen que este enfoque, aunque no resuelve todos los problemas de gobierno de datos, reduce de forma significativa la exposición de información sensible frente a un sistema sin filtrado [9].

4. METODOLOGIA

4.1 Diseño del entorno de prueba

Se propone construir un corpus documental de prueba compuesto por archivos etiquetados en cuatro niveles de clasificación equivalentes a los sugeridos por la norma ISO IEC 27001: público, interno, confidencial y secreto [8]. Cada documento se asocia además a uno o varios roles autorizados, por ejemplo recursos humanos, finanzas o gerencia, y a una lista concreta de usuarios cuando la restricción es individual. Sobre este corpus se despliega un asistente RAG básico que indexa los documentos en un almacén vectorial y responde preguntas de los usuarios recuperando los fragmentos más similares a cada consulta.

4.2 Ataques diseñados

Con base en la taxonomía de vectores descrita en la sección anterior [6, 2], se diseñan tres tipos de intento de exfiltración:

- **Consulta directa:** el usuario pregunta explícitamente por el contenido de un documento cuya clasificación no le corresponde, para verificar si el sistema aplica algún filtro antes de recuperar la información.
- **Reformulación evasiva:** el usuario formula la pregunta de manera indirecta, pidiendo un resumen o una parafrasis del documento restringido, buscando que el filtrado basado en palabras clave no lo detecte.
- **Inyección de instrucciones:** el usuario incluye dentro de su mensaje una orden que le pide al modelo ignorar las restricciones de acceso configuradas en el sistema [4].

4.3 Mecanismos de filtrado evaluados

Se evalúan tres capas de defensa complementarias, siguiendo la lógica de defensa en profundidad recomendada en la literatura sobre control de acceso en RAG [3, 9]:

1. **Filtrado en la recuperación.** Descarta desde el motor de búsqueda todo documento cuyo rol o clasificación no coincida con el perfil autenticado del usuario, antes de que el modelo reciba cualquier fragmento.
2. **Refuerzo del mensaje del sistema.** Recuerda al modelo que nunca debe repetir contenido de fragmentos que no fueron entregados en el contexto autorizado, reduciendo el riesgo de que una inyección de instrucciones logre extraer información de otra fuente.
3. **Validación de la respuesta.** Compara el contenido generado contra los fragmentos efectivamente autorizados antes de entregarlo al usuario, para detectar filtraciones residuales.

5. RESULTADOS Y ANALISIS

5.1 Sistema sin filtrado

Al aplicar los tres ataques descritos sobre un sistema RAG sin ningún filtro, la consulta directa y la reformulación evasiva logran recuperar el contenido de documentos restringidos en la mayoría de los casos, puesto que el motor de búsqueda solo evalúa similitud semántica. Este resultado coincide con lo reportado por OWASP, que ubica la exposición de información sensible como el segundo riesgo más crítico para aplicaciones basadas en modelos de lenguaje precisamente por la frecuencia con la que ocurre en implementaciones reales [2].

5.2 Sistema con filtrado por rol y clasificación

Cuando se incorpora el filtrado a nivel de recuperación por rol y por clasificación, la consulta directa y la reformulación evasiva dejan de tener éxito, porque los fragmentos restringidos ni siquiera llegan al contexto del modelo. Para este tipo de evaluación se propone una métrica llamada ventaja de acceso, que compara la probabilidad de que un usuario no autorizado reciba una respuesta relevante frente a la probabilidad de que la reciba un usuario autorizado; un filtrado correcto en la etapa de recuperación reduce esa ventaja a niveles cercanos a cero [3].

5.3 Riesgo residual

Sin embargo, la inyección de instrucciones sigue representando un riesgo residual. Si el mecanismo de defensa únicamente ocurre en la etapa de recuperación, un atacante que logre manipular el comportamiento del modelo después de que este ya recibió información parcialmente sensible en pasos previos de una conversación extensa podría todavía inducir una revelación indebida. Por esta razón, la validación posterior de la respuesta resulta indispensable como última línea de defensa [9].

6. DISCUSION

6.1 Efectividad frente a las limitaciones conocidas

Los resultados confirman que el filtrado por usuario, rol y clasificación es efectivo contra los vectores de ataque más comunes, pero también evidencian limitaciones importantes que la literatura ya había anticipado. Buena parte de las defensas propuestas hasta ahora actúan de forma reactiva y fragmentada, cubriendo una etapa del pipeline sin coordinarse con las demás, lo que deja huecos que un atacante persistente puede explotar combinando técnicas [6].

6.2 Balance entre seguridad y usabilidad

Un filtrado demasiado estricto puede degradar la utilidad del asistente para usuarios legítimos, generando falsos rechazos cuando la clasificación de un documento no está correctamente etiquetada o cuando un usuario cambia de rol dentro de la organización y sus permisos no se actualizan a tiempo. Ninguna defensa aislada resulta suficiente por sí sola, por lo que la combinación de varias capas complementarias es la estrategia más razonable [3].

6.3 Protección del almacén vectorial

Otro riesgo que la discusión debe reconocer es el de inversión de incrustaciones, mediante el cual un atacante con acceso al almacén vectorial podría reconstruir aproximadamente el texto original de un documento a partir de su representación numérica, incluso si nunca recibió ese documento como respuesta del asistente [2]. Esto implica que el filtrado en la capa de recuperación protege la interfaz conversacional, pero no sustituye la necesidad de proteger también el almacén vectorial con controles de acceso propios y cifrado en reposo.

7. CONCLUSIONES

- Un sistema RAG sin controles de acceso reproduce, y en ocasiones amplifica, el riesgo de exposición de información confidencial, porque su motor de búsqueda recupera contenido por similitud semántica sin considerar quien realiza la consulta.
- Aplicar filtros de acceso por usuario, por rol y por nivel de clasificación en la etapa de recuperación elimina la mayoría de los intentos de exfiltración mediante consultas directas o reformuladas.
- La inyección de instrucciones y la inversión de incrustaciones permanecen como riesgos residuales que exigen capas adicionales de defensa, entre ellas el refuerzo del mensaje del sistema y la validación posterior de cada respuesta.
- La combinación de un esquema de clasificación de la información alineado con la norma ISO IEC 27001 y un modelo de control de acceso basado en roles ofrece una base sólida y verificable para que un asistente virtual construido sobre RAG no revele información confidencial a usuarios no autorizados.

Referencias

- [1] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W. Yih, T. Rocktäschel, S. Riedel, y D. Kiela, "Retrieval augmented generation for knowledge intensive NLP tasks," *Advances in Neural Information Processing Systems*, vol. 33, pp. 9459 a 9474, 2020. <https://arxiv.org/abs/2005.11401>
- [2] OWASP Foundation, *OWASP Top 10 for LLM Applications 2025*, 2025. owasp.org/www-project-top-10-for-large-language-model-applications
- [3] B. Jayaraman, V. J. Marathe, H. Mozaffari, W. F. Shen, y K. Kenthapadi, "Permissioned LLMs: Enforcing access control in large language models," arXiv preprint arXiv:2505.22860, 2025. <https://arxiv.org/abs/2505.22860>
- [4] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, y M. Fritz, "Not what you've signed up for: Compromising real world LLM integrated applications with indirect prompt injection," en *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, 2023, pp. 79 a 90. <https://doi.org/10.1145/3605764.3623985>
- [5] W. Zou, R. Geng, B. Wang, y J. Jia, "PoisonedRAG: Knowledge poisoning attacks to retrieval augmented generation of large language models," arXiv preprint arXiv:2402.07867, 2024. <https://arxiv.org/abs/2402.07867>
- [6] Y. Xu, M. Zhang, Z. Ge, H. Li, N. Hu, Y. Zhang, Z. Wen, J. C. Zhang, Q. Li, y L. Chen, "Securing retrieval augmented generation: A taxonomy of attacks, defenses, and future directions," arXiv preprint arXiv:2604.08304, 2026. <https://arxiv.org/abs/2604.08304>
- [7] R. S. Sandhu, "Role based access control," en *Advances in Computers*, vol. 46, M. V. Zelkowitz, Ed. Elsevier, 1998, pp. 237 a 286. [https://doi.org/10.1016/S0065-2458\(08\)60206-5](https://doi.org/10.1016/S0065-2458(08)60206-5)
- [8] International Organization for Standardization, *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection*, 2022. <https://www.iso.org/standard/27001.html>
- [9] B. Chen, J. Tackman, M. Setälä, T. Poranen, y Z. Zhang, "Integrating access control with retrieval augmented generation: A proof of concept for managing sensitive patient profiles," en *Proceedings of the 40th ACM/SIGAPP Symposium on Applied Computing*, 2025, pp. 915 a 919. <https://doi.org/10.1145/3672608.3707848>